

# Security Linter Report

|                     |                              |
|---------------------|------------------------------|
| Filename            | case2_sql_i_concatenation.py |
| Timestamp           | 2026-05-04 19:12:24 UTC      |
| Lines of Code (LOC) | 3                            |
| Verdict             | VULNERABLE                   |

| ID         | Severity | Sink           | Source Variable | Source Type | Line |
|------------|----------|----------------|-----------------|-------------|------|
| CVE-SL-002 | CRITICAL | cursor.execute | query           | STDIN       | 3    |

|          |   |
|----------|---|
| CRITICAL | 1 |
| WARNING  | 0 |
| INFO     | 0 |
| TOTAL    | 1 |

**CVE-SL-002 — cursor.execute****CRITICAL**

|                              |                              |
|------------------------------|------------------------------|
| <b>CWE</b>                   | CWE-89                       |
| <b>Sink</b>                  | cursor.execute               |
| <b>Sink Line</b>             | 3                            |
| <b>Sink Column</b>           | 0                            |
| <b>Sink Expression</b>       | cursor.execute(query)        |
| <b>Argument</b>              | query                        |
| <b>Source Variable</b>       | query                        |
| <b>Source Type</b>           | STDIN                        |
| <b>Propagation Mechanism</b> | direct assignment from stdin |

***Taint Path Trace:***

| Step | Role   | Line | Expression                                          |
|------|--------|------|-----------------------------------------------------|
| 1    | SOURCE | 2    | query = "SELECT * FROM users WHERE id = " + user_id |
| 2    | SINK   | 3    | cursor.execute(query)                               |

***Remediation:***

Use a parameterized query and validate the input type. If the value must be an integer, cast it with int():

```
user_id = int(input("ID: "))
query = "SELECT * FROM users WHERE id = ?"
cursor.execute(query, (user_id,))
```

No safe sink paths confirmed.

No sanitization functions detected.

|                                          |                |
|------------------------------------------|----------------|
| CFG — Total Nodes                        | 5              |
| CFG — Condition/Loop Nodes               | 0              |
| CFG — Assignment Nodes                   | 2              |
| CFG — Call Nodes                         | 1              |
| CFG — Merge Nodes                        | 0              |
| ████████████████████████████████████████ | ██████████████ |
| DFG — Total Nodes                        | 10             |
| DFG — Total Edges                        | 9              |
| DFG — Source Nodes                       | 2              |
| DFG — Sink Nodes                         | 1              |
| DFG — Operator Nodes                     | 1              |
| DFG — Constant Nodes                     | 2              |
| DFG — Variable Nodes                     | 4              |
| Taint Propagation Hops                   | 3              |
| ████████████████████████████████████████ | ██████████████ |
| Analysis Time (ms)                       | 20.0           |

|                        |                                 |
|------------------------|---------------------------------|
| <b>Vulnerabilities</b> | 1 CRITICAL   0 WARNING   0 INFO |
| <b>Safe Sinks</b>      | 0                               |
| <b>Analysis Time</b>   | 20.0 ms                         |
| <b>Engine Version</b>  | 1.0.0                           |
| <b>Final Verdict</b>   | <b>VULNERABLE</b>               |